

Jason West

COSC 483

Project: Transport Layer Security

26 October 2025

Peer Reviewer: Asa Douglas-Autrey

Quick Summary and Explanation of Each Site Tested

- I. vlr.gg: vlr.gg is a forum website mainly discussing Valorant Esports where you can view each individual game, future games, tournament structure, and news articles. There are multiple different ways you can register for an account (e.g. Reddit, Steam, Riot Games, Twitch, X) so this serves as an important test case.
- II. <https://open.spotify.com/>: Spotify is directly with Apple Music as the 2 most popular and most paid for streaming services in at least North America, and Spotify is the one I personally use as well.
- III. <https://www.wikipedia.org/>: Wikipedia is the most visited and used online encyclopedia, and is often the first website to show up when something simple is googled, like a word or a historical figure/event.
- IV. <https://tiermaker.com/>: TierMaker is an extremely popular website used by many including myself to rank and list literally anything that you could think of. You can create an account where you can save your personal lists and create templates as well.
- V. <https://www.reddit.com/>: Reddit has been reported by IT MANIACS and many others as the most popular forum website–this gives way for many security concerns and spam

issues. Reddit serves as an important test case with these issues as well as the many many subdomains due to threading.

- VI. <https://www.last.fm/>: Last FM is a website where you can link your Spotify account and keep track of your stats. I frequently use this site to check my listening habits and it serves as an important case due to the nature of linking your private spotify account.
- VII. <https://www.youtube.com/>: YouTube is known and used by all as the most frequent source for video content and tutorials. It directly connects to a google account as well if you registered.
- VIII. <https://www.instagram.com/>: Instagram is a social media platform where you can not only post pictures and videos but also communicate with other users as well.
- IX. <https://x.com/>: Formerly known as Twitter, X is another popular social media service with the least moderation out of all of them. With both Instagram above and X, spam, fake, and hacked accounts pose as major security threats.
- X. <https://www.ssllabs.com/ssltest/>: The website we are using to measure TLS configuration.

Key Properties:

Website	Subject/Common Name	Alternative Names	Grade	Validity Period	Key Type
vlr.gg	vlr.gg	api.vlr.gg, vlr.gg, www.vlr.gg	A-	Wed, 08 Oct 2025-Tue, 06 Jan 2026	RSA 2048 bits
Spotify	open.spotify.com	open.spotify.com	A+	Thu, 23 Oct 2025-Sat, 22 Nov 2025	RSA 2048 bits
Wikipedia	*.wikipedia.org	*.m.mediawiki.org *.m.wikibooks.org *.m.wikidata.org *.m.wikimedia.org	A+	Thu, 09 Oct 2025-Wed, 07 Jan 2026	EC 256 bits

		*.m.wikinews.org *. <u>m.wikipedia.org</u> , etc.			
TierMaker	tiermaker.com	*.tiermaker.com	B	Mon, 15 Sep 2025-Sun, 14 Dec 2025	RSA 2048 bits
Reddit	*.reddit.com	reddit.com	A+	Sat, 12 Jul 2025-Wed, 07 Jan 2026	RSA 2048 bits
Last FM	*.last.fm	last.fm	A	Mon, 10 Mar 2025-Wed, 25 Mar 2026	RSA 2048 bits
YouTube	*.google.com	*.android.com *.flash.android.com g.cn *.g.cn g.co *.g.co goo.gl www.goo.gl google-analytics.com *.google-analytics.com google.com googlecommerce.com *.googlecommerce.com ggpht.cn *.ggpht.cn urchin.com *.urchin.com youtube.com youtube.com *.youtube.com music.youtube.com *.music.youtube.com youtubeeducation.com *.youtubeeducation.com youtubekids.com *.youtubekids.com yt.be *.yt.be android.clients.google.com	B	Wed, 01 Oct 2025-Wed, 24 Dec 2025	EC 256 bits
Instagram	*.www.instagram.com	www.instagram.com	A+	Mon, 04 Aug 2025-Sun, 02 Nov 2025	RSA 2048 bits
X	x.com	*.x.com cdn.syndication.x.com x.com	A+	Mon, 13 Oct 2025-Sun, 11 Jan 2026	EC 256 bits
SSL Labs	www.ssllabs.com	ssllabs.com api.ssllabs.com clienttest.ssllabs.com plaintext.ssllabs.com entrust.ssllabs.com globalsign.ssllabs.com casecurity.ssllabs.com wosign.ssllabs.com akamai.ssllabs.com ota.ssllabs.com trustzone.ssllabs.com biznet.ssllabs.com comodo.ssllabs.com globaltrust.ssllabs.com secure128.ssllabs.com	A+	Fri, 25 Jul 2025-Fri, 24 Jul 2026	RSA 2048 bits

Website	Certificate Chain	Authentication Algorithm	Symmetric Encryption Algorithm	Hashing Algorithm	Crypto. Guarantees (C, I, FS)
vlr.gg	<u>vlr.gg</u> → R12 → ISRG Root X1	SHA256 with RSA	AES-256-GCM	SHA384	C, I, FS
Spotify	<u>open.spotify.com</u> → Certainly Intermediate R1 → Starfield Root	SHA256 with RSA	AES-128-GCM	SHA256	C, I, FS

	Certificate Authority - G2				
Wikipedia	*. wikipedia.org → E7 → ISRG Root X1	SHA384 with ECDSA	AES-128-GCM	SHA256	C, I, FS
TierMaker	tiermaker.com → WR1 → GTS Root R1	SHA256 with RSA	AES-128-GCM	SHA256	C, I FS - Partial (modern browsers)
Reddit	*. reddit.com → DigiCert Global G2 TLS RSA SHA256 2020 CA1 → DigiCert Global Root G2	SHA256 with RSA	AES-128-GCM	SHA256	C, I, FS
Last FM	*. last.fm → Sectigo RSA Organization Validation Secure Server CA → USERTrust RSA Certification Authority → AAA Certificate Services	SHA256 with RSA	AES-128-GCM	SHA256	C, I, FS
YouTube	*. google.com → WE2 → GTS Root R4 → GlobalSign RootCA	SHA256 with ECDSA	AES-128-GCM	SHA256	C, I FS - Modern browsers
Instagram	*. www.instagram.com → DigiCert SHA2 High Assurance Server CA → DigiCert High Assurance EV Root CA	SHA256 with RSA	AES-128-GCM	SHA256	C, I, FS
X	x.com → E7 → ISRG Root X1	SHA384 with ECDSA	AES-128-GCM	SHA256	C, I, FS
SSL Labs	www.ssllabs.com → DigiCert Global G2 TLS RSA SHA256 2020 CA1 → DigiCert Global Root G2	SHA256 with RSA	AES-128-GCM	SHA256	C, I, FS

Website	Other Interesting Findings
vlr.gg	Heartbeat extension is disabled, leading to no heartbleed vulnerability. Other common vulnerabilities that it avoids are BEAST (server-side) and POODLE. Certificate transparency is active, meaning it can detect malicious certificates.
Spotify	Heartbeat extension is disabled, leading to no heartbleed vulnerability. Other common vulnerabilities that it avoids are BEAST (server-side), ROBOT, POODLE and Ticketbleed. TLS_FALLBACK_SCSV also enables downgrade attack prevention.
Wikipedia	Heartbeat extension is disabled, leading to no heartbleed vulnerability. Other common vulnerabilities that it avoids are BEAST (server-side), ROBOT, POODLE, and Ticketbleed. HTTP Strict Transport Security (HSTS) is also enforced.
TierMaker	Heartbeat extension is disabled, leading to no heartbleed vulnerability. While POODLE, ROBOT, and Ticketbleed vulnerabilities are still avoided, server-side protections from BEAST attacks are not implemented.
Reddit	Heartbeat extension is disabled, leading to no heartbleed vulnerability. Other common vulnerabilities that it avoids are BEAST (server-side), ROBOT, POODLE and Ticketbleed. HSTS is also implemented, enforcing HTTPS to all subdomains (e.g. threads).
Last FM	Heartbeat extension is disabled, leading to no heartbleed vulnerability. Other common vulnerabilities that it avoids are BEAST (server-side), ROBOT, POODLE and Ticketbleed. HSTS is enabled but not preloaded, and it only lasts for 5 min (300 sec from max-age=300).
YouTube	Heartbeat extension is disabled, leading to no heartbleed vulnerability. While POODLE, ROBOT, and Ticketbleed vulnerabilities are still avoided, server-side protections from BEAST attacks are not implemented. TLS_FALLBACK_SCSV support also enables downgrade attack prevention.
Instagram	Heartbeat extension is disabled, leading to no heartbleed vulnerability. Other common vulnerabilities that it avoids are BEAST (server-side), ROBOT, POODLE and Ticketbleed. Upon seeing that the certificate expired in 7 days, it sparked interest in the fact that the certificate only lasts just under 90 days (3 months).
X	Heartbeat extension is disabled, leading to no heartbleed vulnerability. Other common vulnerabilities that it avoids are BEAST (server-side), ROBOT, POODLE and Ticketbleed. While HSTS is not preloaded, it lasts for ~20 years (max-age=631138519).
SSL Labs	Just like every site it tested, the heartbeat extension is disabled, leading to no heartbleed vulnerability. Other common vulnerabilities that it avoids as well are BEAST, ROBOT, POODLE and Ticketbleed. However, future security is only ensured on “most browsers”, which is interesting and ironic considering this is the site we are using to test future TL security.

Summary of Overall Observations

To get a great balance of test cases going into this experience, I chose 3 niche websites that I use very frequently, 4 popular websites that I use very frequently (X, Instagram, Spotify, YouTube), and 3 popular websites that are used a lot but I don't necessarily have as much experience with (Wiki, Reddit, SSL Labs). Because of this selection, I had many expectations going into the testing. For the more niche, less renowned websites, I expected the analysis to take

longer and the overall grade of the website to be lower, as well as have less defenses against common TLS breaches/attacks. The analysis did take significantly longer, as common websites like X, YouTube, and Wikipedia produced a report almost instantly, whereas it took around 59 seconds for Last FM and vlr.gg. However, I was very surprised to find that only TierMaker (the most popular of the 3) had a relatively bad rating (B) along with YouTube, which is arguably the most visited site out of all ten that I analyzed. Both of these websites also only ensured forward security for modern and updated browsers only. In reference to defense against common TLS attacks, the only TLS attack that was not defended by all websites was BEAST. It makes sense why heartbleed was never a problem because all you have to do is disable the heartbleed extension and there's no method of attack, but it was interesting how *all* websites were protected from various different POODLE attacks as well. In combination with this defense, it also seemed like every website that had short-lived valid certificates had a high rating—this could be due to the constant rotation reducing the window where damage could be conducted. It's also interesting to note that all websites but one (vlr.gg) preferred the symmetric encryption algorithm AES-128-GCM paired with the SHA-256 hashing algorithm. This is most likely due to this combination offering a good balance of security, efficiency, and wide-spread hardware support, making it the common standard for TLS connections on websites. The security difference between that and something like AES-256-GCM paired with SHA-384 is not drastic enough to sacrifice performance. Overall, the analysis of these ten websites revealed that most modern websites follow relatively similar TLS practices—nearly all relied on AES-128-GCM with forward secrecy—with minor differences in preferences on balancing performance and long-term security.

Questions

The first bit of confusion I ran into was a listing of 2 completely different certificates, where the second certificate would appear “Not Trusted” and have mismatches on the alternative names. This leads to two questions for me: Why would a server maintain multiple certificates if one is untrusted or invalid? Does having multiple certificates actually improve security without sacrificing compatibility, performance or accessibility?

I also noticed some sites listed multiple authentication algorithms/cipher suites, but in preferred order (I put the #1 preferred option for each one with multiple). What determines that preference—is it based on trade-offs which sacrifice performance for cryptographic strength?